FICHE 23 – APPLICATIONS MOBILES : CONCEPTION ET DÉVELOPPEMENT

Appliquer les principes de sécurité de base au développement des applications mobiles.

Les applications mobiles sont l'un des principaux moyens d'accès à des contenus et des services numériques et impliquent pour la plupart le traitement de données personnelles. Il est nécessaire pour les éditeurs de sécuriser ces traitements et d'offrir la meilleure transparence possible aux utilisateurs.

Les précautions élémentaires

- **Minimiser les traitements de données personnelles mis en œuvre** en s'assurant que chaque type de données collectées est bien nécessaire au fonctionnement de l'application.
- Choisir, lors de leur sélection, les permissions pertinentes au fonctionnement de l'application et impliquant le minimum de collecte supplémentaire, voire proposer des alternatives à l'utilisateur ne reposant pas sur des permissions (ex. : la géolocalisation permet de simplifier une recherche géographique, mais peut être remplacée par la saisie manuelle de l'adresse).
- **Sécuriser les communications**, au moins avec les serveurs, en les encapsulant dans un canal TLS, en respectant le guide TLS de l'ANSSI[121].
- **Stocker les secrets cryptographiques par empaquetage** au moyen d'API permettant l'utilisation des suites cryptographiques incluses dans le téléphone, en privilégiant les protections matérielles telles que le « *Hardware Keystore* »[122] d'Android ou la « *Secure Enclave* »[123] d'Apple.
- **Prendre en compte la possibilité que le système d'exploitation effectue des sauvegardes automatiques des données personnelles**, quelles qu'elles soient. Désactiver les sauvegardes non souhaitées ou procéder à un chiffrement des données sans inclure la clé de chiffrement dans les sauvegardes.
- **Recourir à un moyen d'authentification correspondant au niveau de sécurité recherché** lorsqu'une authentification est nécessaire (ex. : si une personne doit être authentifiée avec certitude, ne pas recourir à un moyen d'authentification biométrique si le dispositif utilisé permet l'enregistrement de gabarits biométriques de plusieurs personnes).

121 « Recommandations de sécurité relatives à TLS », cyber.gouv.fr

122 « Keystore soutenu par le matériel », source.android.com

123 « Secure Enclave », support.apple.com